

Sprint 1 : Sécurisation du site internet

US1 : Sécuriser les communications du site web

Objectif : Assurer que toutes les communications sont chiffrées via HTTPS.

Mode d'emploi :

1. Vérifier si un certificat SSL/TLS est installé sur le serveur.
2. Installer un certificat SSL/TLS (ex. Let's Encrypt pour une solution gratuite).
3. Configurer le serveur web (Apache, Nginx) pour forcer l'usage de HTTPS.
4. Activer HSTS (HTTP Strict Transport Security) pour interdire HTTP.
5. Tester avec des outils comme SSL Labs.

Outils recommandés : Let's Encrypt, OpenSSL, Certbot, Apache/Nginx.

US2 : Mettre en place une gestion sécurisée des authentifications

Objectif : Sécuriser l'authentification des utilisateurs.

Mode d'emploi :

1. Forcer une politique de mots de passe robustes (ex : minimum 12 caractères, majuscules, chiffres, caractères spéciaux).
2. Utiliser un algorithme de hachage sécurisé pour stocker les mots de passe (ex: bcrypt, Argon2).
3. Implémenter l'authentification à deux facteurs (2FA) si nécessaire.
4. Limiter les tentatives de connexion pour éviter les attaques par force brute.

Outils recommandés : bcrypt, Argon2, Google Authenticator, reCAPTCHA, Fail2Ban.

US3 : Protéger l'accès aux interfaces d'administration

Objectif : Restreindre l'accès à l'interface admin.

Mode d'emploi :

1. Créer un système d'authentification pour l'admin (login + 2FA).
2. Restreindre l'accès via une liste blanche d'IP autorisées.
3. Vérifier les permissions des utilisateurs.
4. Ajouter des logs pour suivre les connexions suspectes.

Outils recommandés : Google Authenticator, UFW (firewall), Logs d'Apache/Nginx.

US4 : Implémenter la gestion des sessions et cookies sécurisés

Objectif : Protéger les sessions contre les attaques CSRF/XSS.

Mode d'emploi :

1. Activer les options **Secure**, **HttpOnly** et **SameSite** pour les cookies.
2. Générer des jetons CSRF et les valider à chaque requête sensible.
3. Empêcher la fixation de session en régénérant les IDs après connexion.

Outils recommandés : OWASP CSRF Guard, JWT, Express-session.

US5 : Contrôler et journaliser les accès au système

Objectif : Traquer les actions sensibles pour détecter d'éventuelles attaques.

Mode d'emploi :

1. Configurer un système de logs (ex: stockage des tentatives de connexion, erreurs d'authentification).
2. Implémenter une alerte en cas de comportement suspect (ex: 5 tentatives de connexion échouées).
3. Utiliser un outil de SIEM (ex: ELK, Splunk) pour analyser les journaux.

Outils recommandés : ELK Stack, Graylog, Splunk.

US6 : Créer une base de données pour stocker les mails et messages des personnes qui nous contactent

Objectif : Enregistrer de manière sécurisée les messages envoyés via le formulaire de contact.

Mode d'emploi :

1. Concevoir une base de données (ex: table **messages** avec **email**, **message**, **date**).
2. Chiffrer les emails avant stockage (ex: AES-256).
3. Mettre en place un système de purge automatique des anciens messages.
4. Ajouter une validation pour éviter les attaques SQLi/XSS.

Outils recommandés : MySQL/MariaDB, PostgreSQL, PHP PDO, SQLAlchemy.

US7 : Créer un espace d'administration avec un calendrier de travail

Objectif : Permettre à l'équipe d'organiser ses tâches via un calendrier.

Mode d'emploi :

1. Ajouter une interface dédiée pour l'admin.
2. Implémenter une base de données pour stocker les événements (**titre**, **date**, **description**).
3. Permettre l'ajout, modification et suppression d'événements.
4. Sécuriser l'accès à cet espace.

Outils recommandés : FullCalendar.js, Firebase, MySQL/PostgreSQL.

Sprint 2 : Audit et tests de sécurité

US8 : Sécuriser les bases de données

Objectif : Protéger la base de données contre les attaques.

Mode d'emploi :

1. Restreindre les accès et permissions (principe du moindre privilège).
2. Chiffrer les données sensibles (ex: AES-256 pour les emails).
3. Utiliser des requêtes préparées pour éviter les injections SQL.
4. Vérifier les logs pour identifier les tentatives d'attaques.

Outils recommandés : MySQL, PostgreSQL, MongoDB, HashiCorp Vault.

US9 : Réaliser une analyse des dépendances et bibliothèques utilisées

Objectif : Identifier les composants vulnérables du projet.

Mode d'emploi :

1. Lister toutes les dépendances avec **npm audit**, **pip list**, **composer audit**.
2. Mettre à jour les versions obsolètes et corriger les failles de sécurité.
3. Vérifier les permissions et supprimer les bibliothèques inutilisées.

Outils recommandés : OWASP Dependency-Check, Snyk, GitHub Dependabot.

US10 : Mettre en place des tests d'intrusion automatisés

Objectif : Identifier les vulnérabilités du site avant mise en production.

Mode d'emploi :

1. Utiliser un scanner de vulnérabilités comme OWASP ZAP ou Burp Suite.
2. Simuler des attaques XSS, SQLi et CSRF.
3. Analyser les rapports et corriger les failles détectées.

Outils recommandés : OWASP ZAP, Burp Suite, Nikto.

US11 : Vérifier la conformité RGPD

Objectif : S'assurer que les données personnelles sont bien protégées.

Mode d'emploi :

1. Vérifier la collecte et le stockage des données personnelles.
2. Mettre en place une page pour que les utilisateurs puissent demander la suppression de leurs données.
3. Anonymiser ou pseudonymiser les données sensibles.

Outils recommandés : CNIL GDPR Toolbox, Privacy by Design.

US12 : Tester la résilience aux attaques de type injection SQL et XSS

Objectif : Vérifier que le site est protégé contre ces menaces.

Mode d'emploi :

1. Tester l'injection SQL en saisissant des commandes malveillantes (' OR 1=1 --).
2. Vérifier si les champs acceptent du code HTML malveillant (`<script>alert('XSS')</script>`).
3. Corriger avec des requêtes préparées et une validation stricte des entrées.

Outils recommandés : SQLmap, XSS Hunter.

US13 : Mettre en place un plan de réponse aux incidents

Objectif : Définir une procédure en cas d'attaque ou de fuite de données.

Mode d'emploi :

1. Identifier les risques et établir un protocole de réaction.
2. Définir une procédure de notification en cas de violation de données.
3. Mettre en place une sauvegarde régulière et sécurisée des données.

Outils recommandés : Playbooks SIEM, Runbooks DevSecOps.